SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSIGNMENT 1

QUESTIONS

CO1: Apply classical encryption techniques using symmetric and asymmetric ciphers to encrypt and decrypt data for the ensuring data security.

Assignment Title: Evaluate, Design and Defend a Secure Patient-Record Exchange Strategy for a Multi-Hospital Healthcare Network (Total Marks: 50)

Name: K Sumanth Kumar Reddy
Reg No: 192425222
Course Code: CSA5102
Course Name: Cryptography and Network Security

Scenario — Confidential Patient Record Exchange

A regional healthcare network links one central hospital with 25 satellite clinics. Clinics send patient records, diagnostic reports, prescriptions and billing data to the central hospital over a public network and receive specialist opinions in return. Personnel hold different clearance levels: Medical Director (Top Secret), Specialist Doctors (Secret), Nurses and Lab Staff (Confidential), Billing and Front-Desk Staff (Restricted), Patients (Public).

The system must:

- Keep diagnoses, especially for sensitive conditions, confidential.
- Detect tampering with prescriptions, dosage and lab values.
- Prevent staff from reading or writing records beyond their clearance.
- Work in rural clinics where staff have limited technical training and hardware is basic.

You must evaluate, design and defend a protection strategy built only from classical (pre-modern) techniques and access-control reasoning

covered in CO1. You are expected to judge how strong each technique actually is, not just describe it.

Design Challenge : An insider at a satellite clinic has been copying ciphertexts for months. Hundreds of messages under the same key are now exposed, and many begin with predictable text (e.g., "PATIENT ID", "DIAGNOSIS:", "PRESCRIPTION:"). The network also wants to embed a short report inside medical scan images sent between

hospitals. Re-evaluate your design.

- Encrypt clinical notes (200 to 10,000 characters) using Caesar, monoalphabetic, Vigenère and columnar transposition, and derive each key space. Break at least three schemes by frequency analysis, Kasiski or index of coincidence, and rank the schemes by resistance.
- Extend the alphabet to digits and symbols (mod 36) and encrypt IDs and dosages such as PT-20481, AMOX 500MG using a Hill cipher on 3-character blocks. Prove the key's invertibility, compute one inverse, and recover the key by a known-plaintext attack.
- Apply columnar transposition to a lab table of 20+ rows and test whether a changed cell or a swapped row is detected. Design a classical checksum and show where an attacker defeats it.
- Encrypt a 256×256 or larger medical image with two classical methods (intensity shift mod 256 and pixel permutation) and verify decryption. Compare histograms and entropy, and explain which method leaks the image's structure.
- Hide a short report in an image by LSB embedding and in a text circular by a text method, then extract it. Measure PSNR, capacity and chi-square detectability, and test survival under JPEG compression.
- Decide 12+ access requests using Bell-LaPadula with compartments, including declassification and break-glass cases. Rank six attacks by likelihood × impact and recommend

a final design, stating which security goals classical techniques cannot meet.

TASK 1 – Evaluate Threats, Attacks and Risks 4 Marks

Identify at least six security attacks relevant to the healthcare scenario.

- Classify each as passive or active (eavesdropping, traffic analysis, modification of prescriptions, masquerade as a doctor, replay of old orders, denial of service on the records system).
- Distinguish clearly between threat, vulnerability, attack and risk, with examples from this scenario.
- Rank the attacks by risk using a justified likelihood × impact rating. Consider patient-safety impact, not just privacy.
- Defend your ranking: which attack would you address first, and why?

Evidence Expected: A risk table with reasoned ratings and a justification of the priority order.

TASK 2 – Map and Judge Security Goals 3 Marks

For each system function (record upload, prescription transmission, specialist consultation), decide which goals matter most: confidentiality integrity availability authentication non-repudiation

- Judge which goals classical ciphers can and cannot deliver.
- Justify why a correctly decrypted message does not prove it came from the right doctor, or that its dosage was not altered.

Evidence Expected: A goal-to-function analysis with an evaluation of the gaps classical techniques leave.

TASK 3 – Apply and Critique the Bell-LaPadula Model 5 Marks

- Define the security levels and subject/object assignments for the network.
- Apply the simple security property (no read up) and the *-property (no write down) to at least five

access requests, including two that must be denied. Show the reasoning for each.

- Evaluate the model critically in a medical setting: what happens in an emergency when a nurse needs a Secret-level allergy record? How does the model handle a doctor who must write a note to a lower-level billing file? Discuss tranquility and trusted subjects.
- Judge the model's limitations (no integrity guarantees, covert channels, rigidity in emergencies) and argue whether Bell-LaPadula alone suits healthcare.

Evidence Expected: Worked access decisions, a justified critique, and a clear verdict on the model's suitability.

TASK 4 – Design the Cryptographic Strategies 4 Marks

Select at least three meaningfully different classical schemes from: Caesar, monoalphabetic substitution, Vigenère (polyalphabetic), Hill cipher, a transposition cipher. For each, provide:

- The encryption and decryption algorithm (pseudocode or formula) and the key definition.

- A worked example on a 20+ character message from the scenario.
- A justification for including it in your comparison.

Evidence Expected: Three distinct schemes with algorithms, worked examples and justified selection.

TASK 5 – Mathematical Analysis of the Schemes 5 Marks

- Derive the key-space size of each scheme (e.g., 25, 26!, 26^m, number of invertible n×n matrices mod 26, n! permutations).
- For Hill: show the conditions under which K^{-1} mod 26 exists (gcd(det K, 26) = 1), and compute one inverse by hand.
- Express each encryption as a modular function (e.g., C = (aP + b) mod 26 for an affine variant, C = KP mod 26 for Hill).
- Judge whether a large key space guarantees strength. Support your answer with the monoalphabetic example.

Evidence Expected: Correct derivations with a reasoned judgment on key space versus real security.

TASK 6 – Evaluate Cryptanalytic Resistance 4 Marks

Attack each chosen scheme using a technique suited to it:

- Brute force, frequency analysis, Kasiski examination / index of coincidence, known-plaintext attack on Hill, digram analysis.
- Explain why each attack succeeds or fails, in terms of letter-frequency preservation, key repetition and linearity.
- Rank the schemes by resistance and justify the ranking with evidence.

Evidence Expected: Worked attacks with reasoning, and a ranking of schemes supported by the results.

TASK 7 – Assess Transposition and Product Ciphers 3 Marks

- Implement a columnar (or rail-fence) transposition and explain how it diffuses plaintext structure.
- Evaluate whether *substitution followed by transposition* is stronger than either alone. Justify with letter-frequency evidence and an attack attempt.
- Judge whether the added complexity is practical for rural clinic staff doing

manual or low-resource encryption.

Evidence Expected: A reasoned evaluation of the combined scheme against its components.

TASK 8 – Evaluate Steganography 3 Marks

Design a steganographic method (e.g., LSB embedding in a scan image, or text-based hiding) for carrying a short report inside a medical image.

- Compare it with encryption on capacity, imperceptibility, robustness and detectability.
- Evaluate the risk specific to medical imaging: could embedding alter pixel data enough to affect a diagnosis? Judge the trade-off.
- Judge when steganography is appropriate, and argue why hiding is not a substitute for encrypting. Evaluate an encrypt-then-embed approach.

Evidence Expected: A criteria-based comparison with a justified conclusion.

TASK 9 – Implement and Test
4 Marks

Implement all chosen schemes, the cryptanalysis tools and (where feasible) the steganography method, in a language of your choice.

- Provide correctness tests: decrypt(encrypt(m)) = m, including edge cases (digits in patient IDs, punctuation, non-multiple block length for Hill).
- Use identical plaintexts of 100, 1,000, 10,000 and 100,000 characters across schemes.
- State the testing procedure clearly so it can be reproduced.

Evidence Expected: Working code with a documented, reproducible test procedure.

TASK 10 – Record and Interpret Experimental Evidence
3 Marks

Present data in tables and graphs for:

- Letter-frequency histograms of plaintext versus each ciphertext.
- Index of coincidence per scheme.
- Encryption/decryption time against message size.
- Attack success rate against

ciphertext length. Evaluate what the

data shows. Do not just present it.

Evidence Expected: Clear, comparable results with interpretation tied to Tasks 5 and 6.

TASK 11 – Recommend and Defend the Final Design
4 Marks

Recommend one scheme, or a layered combination, together with the Bell-LaPadula policy.

- Justify against the alternatives using your mathematical and experimental evidence.
- State the residual risks and limitations honestly. Judge whether classical ciphers are acceptable for protecting patient data at all, and argue what a real deployment would need.
- Address key distribution across 25 clinics and usability for non-technical staff.

Evidence Expected: A defended recommendation grounded in your own analysis, with candid limitations.

DAY-4 DESIGN CHALLENGE

TASK 12 – Re-evaluate and Adapt the Design 8 Marks

Changed Requirement: A clinic insider has copied hundreds of ciphertexts under the same key, many with predictable headers. The network also wants reports hidden inside medical scan images.

You may RETAIN → MODIFY → or REDESIGN your original solution.

A. Impact Analysis (2 Marks)

- What has changed in the threat model (insider versus external attacker)?
- Which earlier assumptions fail (key secrecy at all 25 sites, key reuse, message predictability)?
- Why does a high volume of known-format messages change the risk ranking?

B. Evaluation of the Original Design (2 Marks)

- Test your recommended scheme against the new attacker capabilities (known-plaintext, repeated-key attacks).
- Support the evaluation with a demonstration or calculation.
- Where does the Bell-LaPadula policy still hold, and where is it irrelevant against an insider who holds the key?

C. Adaptation or Redesign (2 Marks)

- Decide to retain, modify or redesign. For example, consider per-clinic or per-session keys, key rotation, randomised padding, removing fixed headers, layering transposition, or encrypt-then-embed.
- Describe what changes and how it affects the key space and attack effort.

D. Evidence-Based Defence (2 Marks)

Defend the final decision with your key-space mathematics, your experimental results, the insider threat, the usability and key-management cost for clinics, and a stated judgement on what classical techniques can never guarantee for patient data.

MARK DISTRIBUTION

Task	**Marks**
Task 1 – Threats, Attacks and Risk Evaluation	4
Task 2 – Security Goals Mapping	3
Task 3 – Bell-LaPadula Application and Critique	5
Task 4 – Cipher Design	4
Task 5 – Mathematical Analysis	5
Task 6 – Cryptanalytic Resistance	4
Task 7 – Transposition / Product Ciphers	3
Task 8 – Steganography Evaluation	3
Task 9 – Implementation & Testing	4
Task 10 – Experimental Evidence	3
Task 11 – Final Design Recommendation	4
Subtotal	**42**
Task 12 – Day-4 Design Challenge	**8**
TOTAL	**50**

TASK 1 – Evaluate Threats, Attacks and Risks (4 Marks)

The first task identifies security attacks that can affect the patient-record exchange network. A healthcare system must evaluate both information loss and patient-safety consequences. An attack that changes a medicine dosage may be more dangerous than an attack that only reveals message timing. Risk assessment helps the network decide which weaknesses should be addressed first.

1.1 Meaning of Threat, Vulnerability, Attack and Risk

A threat is a possible event or actor that can cause harm. For example, a dishonest clinic employee, an external attacker or malware may threaten patient records. A vulnerability is a weakness that makes the threat possible, such as a shared encryption key, weak passwords, unprotected computers or missing audit logs. An attack is the actual attempt to exploit a vulnerability. Risk is the expected level of harm, commonly estimated by multiplying likelihood by impact. In this scenario, a clinic employee copying ciphertexts is an attack that exploits weak insider monitoring and excessive access. The risk depends on how likely copying is and how much damage could follow.

1.2 Passive Attacks

Passive attacks observe information without changing it. Eavesdropping occurs when an attacker listens to network traffic and collects messages. If messages are not encrypted, diagnoses and prescriptions may be exposed directly. If classical encryption is used, an attacker can still collect ciphertexts for later frequency analysis. Traffic analysis does not require reading the message content. The attacker observes which clinic communicates with the central hospital, the time of communication, message size and frequency. A sudden increase in messages may reveal an emergency or specialist consultation. Passive attacks are difficult to notice because the data may remain unchanged.

1.3 Active Attacks

Active attacks change, insert, delete or interrupt information. Prescription modification is especially serious: changing a dosage from the doctor's intended value may result in an overdose or ineffective treatment. Masquerade occurs when an attacker pretends to be an authorized doctor or clinic and sends false instructions. Replay occurs when an old valid prescription is captured and transmitted again, even though it may no longer be appropriate. Denial of service makes the records system unavailable by flooding a server, disrupting a connection or exhausting resources. Active attacks can affect both confidentiality and patient safety.

1.4 Risk Ranking

A simple rating uses likelihood and impact from 1 to 5. A score of 1–5 is low, 6–10 is moderate, 11–15 is high and 16–25 is very high. These values are judgement-based estimates for prioritization, not measured probabilities. The impact rating considers privacy, financial damage, clinical disruption and possible harm to a patient.

1.5 Justification and Priority

Insider copying is ranked first because the scenario explicitly describes an employee collecting hundreds of ciphertexts over several months. Repeated messages under one key can reveal patterns and support known-plaintext attacks. Prescription modification, masquerade and replay also receive high priority because they may cause incorrect treatment. Eavesdropping threatens confidentiality, while denial of service can prevent clinicians from seeing necessary records. Traffic analysis is lower in direct impact but may reveal sensitive operational patterns. The first response should contain the insider threat, review access permissions, preserve audit evidence, rotate exposed keys and investigate whether plaintext records were also copied. In parallel, prescription workflows require authenticated senders, timestamps or sequence numbers, and tamper detection. Classical ciphers alone cannot provide these guarantees.

Risk table

Attack	Class	Likelihood	Impact	Score	Reason
Eavesdropping	Passive	4	4	16 – Very high	Clinical data may be exposed.
Traffic analysis	Passive	4	2	8 – Moderate	Reveals communication patterns.
Prescription modification	Active	3	5	15 – High	May cause incorrect treatment.
Masquerade as doctor	Active	3	5	15 – High	False clinical instructions may be trusted.
Replay of old order	Active	3	5	15 – High	Outdated medicine orders may be reused.
Denial of service	Active	3	4	12 – High	Clinicians may lose access to records.
Insider ciphertext copying	Insider/passive collection	4	5	20 – Very high	Large repeated dataset supports analysis.

TASK 2 – Map and Judge Security Goals (3 Marks)

This task maps the five main security goals to record upload, prescription transmission and specialist consultation. The network must not assume that encryption solves every security problem. Different functions need different protections, and clinical integrity is particularly important because inaccurate data can influence diagnosis and treatment.

2.1 Confidentiality

Confidentiality means that information is disclosed only to authorized people. During record upload, diagnoses, patient identifiers and test reports should be protected from outsiders and staff without a valid reason to access them. Prescription transmission must hide the medicine, dosage and patient details from unauthorized observers. Specialist consultation may contain highly sensitive details and therefore requires strict confidentiality. Classical substitution and transposition can make text less readable, but their small or structured key spaces make them weak against analysis. They should be treated as classroom examples only.

2.2 Integrity

Integrity means that data remains complete and unchanged except through authorized updates. A prescription must arrive with the same medicine and dosage selected by the doctor. Laboratory values must not be altered during transfer or storage. A classical cipher does not inherently detect a changed character. An attacker can modify a ciphertext and the receiver may decrypt it into a different message. A simple checksum can detect accidental errors, but an attacker may change the message and recompute an unkeyed checksum. Real systems require a cryptographic message authentication code or authenticated encryption.

2.3 Availability

Availability means that authorized staff can obtain records when they need them. A network outage, server failure or denial-of-service attack may prevent a clinic from obtaining a specialist opinion. Encryption does not make a server available. The system should have backups, redundant connections where possible, recovery procedures and a carefully controlled downtime process. Rural clinics may need a safe offline workflow that synchronizes records after connectivity returns.

2.4 Authentication and Non-repudiation

Authentication verifies who sent or received a message. A ciphertext that decrypts correctly does not prove that a doctor created it. Anyone who knows a shared classical key can generate a ciphertext that appears valid. Non-repudiation provides evidence that a sender cannot reasonably deny creating or approving a message. Classical ciphers do not provide digital signatures. A real prescription workflow should identify the prescriber, bind approval to the exact prescription content and preserve a reliable audit trail.

2.5 Goal-to-Function Analysis

Record upload needs confidentiality and integrity because complete patient files are transferred. Authentication is needed to confirm the sending clinic, and availability ensures the hospital receives the data. Prescription transmission places the highest priority on integrity and authentication because the medicine and dosage must be correct and attributable to the doctor. Specialist consultation requires confidentiality, authentication and integrity so that only the correct specialists participate and their advice is not modified. Non-repudiation is especially useful for prescriptions and clinical approvals.

2.6 Why Correct Decryption Is Not Proof

Decryption is a mathematical operation using a key and an algorithm. It answers whether a ciphertext can be transformed into readable text. It does not answer who created the ciphertext, whether the sender was authorized, or whether the message was changed before encryption. If several doctors share one key, the receiver cannot

distinguish which doctor sent a message. If an attacker modifies a ciphertext, the receiver may obtain altered plaintext without an error. Therefore encryption, authentication and integrity must be treated as separate requirements.

Function	Confidentiality	Integrity	Availability	Authentication	Non-repudiation
Record upload	High	High	High	High	Medium
Prescription	High	Very high	High	Very high	High
Specialist consultation	Very high	High	High	High	Medium/High

The table uses qualitative priorities. The exact implementation must follow the hospital's clinical policies and legal requirements. Classical ciphers can demonstrate confidentiality concepts but cannot meet the full set of security goals.

TASK 3 – Apply and Critique the Bell-LaPadula Model (5 Marks)

Bell-LaPadula (BLP) is a formal access-control model designed to protect confidentiality in systems with security classifications. It is relevant to this network because users have different clearance levels and patient information has different sensitivity levels. BLP controls information flow based on the subject's clearance and the object's classification.

3.1 Security Levels and Assignments

The scenario specifies five levels. Top Secret is assigned to the Medical Director, Secret to Specialist Doctors, Confidential to Nurses and Laboratory Staff, Restricted to Billing and Front-Desk Staff, and Public to Patients. Objects such as records, reports and files receive classification labels. For example, a specialist diagnosis may be Secret, a nursing observation may be Confidential, billing information may be Restricted, and public health instructions may be Public. In practice, classification alone is not enough: patient assignment, department, purpose and consent may also matter.

3.2 Simple Security Property – No Read Up

The simple security property states that a subject cannot read an object at a higher security level than the subject's clearance. A Confidential nurse cannot read a Secret specialist diagnosis because that would be reading up. A Restricted billing clerk cannot read a Confidential laboratory report. A Medical Director at Top Secret can read lower-level objects, provided other access conditions are satisfied. The rule prevents lower-cleared users from obtaining higher-classified information.

3.3 Star Property – No Write Down

The *-property states that a subject cannot write information to a lower classification level. This prevents a user who has read sensitive information from copying it into a lower-level object. For example, a specialist doctor who has read a Secret diagnosis must not write that diagnosis into a Restricted billing file. A carefully approved process may create a limited billing statement containing only the amount due, but this is controlled declassification rather than unrestricted copying.

3.4 Worked Access Decisions

A Specialist Doctor reading a Secret consultation is allowed because the subject and object are at the same level. A nurse reading a Confidential lab result is allowed by level, assuming the nurse is assigned to that patient. A nurse reading a Secret allergy record is denied by default because the object is above the nurse's Confidential clearance. A billing clerk reading a Secret diagnosis is denied because Restricted is below Secret. A Medical Director reading a Confidential report is allowed by the level rule. A Specialist Doctor writing a Secret diagnosis into a Restricted billing file is denied by no-write-down. A patient reading a Public health instruction is allowed. A patient attempting to read another patient's private record must still be denied by identity and ownership rules; BLP classification alone does not express every patient relationship.

3.5 Emergency and Break-Glass Access

Healthcare creates emergency situations that are difficult for strict hierarchical models. A nurse may need a Secret allergy record to prevent a dangerous drug interaction. Normal BLP rules deny that access. A break-glass process can provide temporary emergency access after the user states a reason. The system should record the user, patient, time, records viewed and reason. It should notify a supervisor and require retrospective review. Emergency access should be limited to the minimum necessary information and should not become a routine bypass.

3.6 Trusted Subjects, Declassification and Tranquility

A trusted subject is an authorized process or person allowed to perform a controlled security-sensitive action. A doctor may prepare a billing summary by removing diagnosis details and retaining only necessary billing data. The doctor or trusted process must verify that no higher-level information is leaked. Tranquility refers to preventing labels from being changed in ways that undermine the policy. Stable labels reduce the risk that an object is downgraded simply to permit access.

3.7 Limitations and Verdict

BLP is focused on confidentiality. It does not guarantee that a prescription is accurate, that laboratory values are unchanged, or that the system remains available. It does not automatically prevent covert channels, screenshots, photographing a display or misuse by a user who is legitimately allowed to read information. It can also be too rigid during emergencies. Therefore BLP alone is not suitable for a complete healthcare security system. It should be combined with role-based access, patient-care relationships, integrity controls, authentication, auditing and emergency access procedures.

Subject and request	Decision	BLP reasoning
Specialist reads Secret consultation	Allow	Same level; no read up.
Nurse reads Secret allergy record	Deny normally	Confidential cannot read Secret.
Nurse reads Confidential lab result	Allow conditionally	Same level; patient assignment still required.
Billing clerk reads Secret diagnosis	Deny	Restricted cannot read Secret.
Specialist writes Secret diagnosis to Restricted billing file	Deny	No write down.
Medical Director reads Confidential report	Allow	Top Secret subject may read lower level.
Patient reads Public instructions	Allow	Public-level access, subject to identity rules.

TASK 4 – Design the Cryptographic Strategies (4 Marks)

This task selects several classical schemes and explains their keys, encryption rules and decryption rules. The selected methods are meaningfully different: Caesar and monoalphabetic substitution use fixed substitutions, Vigenère uses a repeating sequence of shifts, Hill uses matrix multiplication, and columnar transposition rearranges character positions. Worked examples use healthcare-related text.

4.1 Caesar Cipher

The Caesar cipher replaces each letter with another letter a fixed number of positions later in the alphabet. Let A=0, B=1, …, Z=25. The key k is an integer from 0 to 25. Encryption is $C=(P+k) \bmod 26$ and decryption is $P=(C-k) \bmod 26$. For example, using k=3, the plaintext PATIENT becomes SDWLHQW. A longer example is PATIENT RECORDS ARE PRIVATE, which becomes SDWLHQW UHFRUGV DUH SULYDWH when letters are shifted by three and case is normalized. Spaces are retained. The method is easy to understand and useful for demonstrating modular arithmetic, but the key space is tiny.

4.2 Monoalphabetic Substitution

A monoalphabetic substitution cipher uses one fixed permutation of the alphabet. The key is a scrambled alphabet containing every letter exactly once. A keyword can generate the substitution alphabet. For keyword CIPHER, write CIPHER first and then append the unused letters in normal alphabetical order. Each plaintext letter is replaced by the corresponding letter in the cipher alphabet. Decryption uses the reverse mapping. This method has many possible keys, but every occurrence of a plaintext letter maps to the same ciphertext letter. Therefore the frequency pattern remains visible.

4.3 Vigenère Cipher

Vigenère uses a keyword to select a different shift for each plaintext letter. Convert letters to numbers from 0 to 25. Repeat the key to match the message length. Encryption is $C_i=(P_i+K_i) \bmod 26$ and decryption is $P_i=(C_i-K_i) \bmod 26$. For example, plaintext PATIENTRECORDS and key CLINICCLINICCL are aligned letter by letter and each pair is added modulo 26. The key is repeated, so a short key creates periodic patterns. It is stronger than Caesar against simple frequency analysis but is not secure when the key is reused.

4.4 Hill Cipher

The Hill cipher transforms a block of letters using matrix multiplication. For a two-letter block, use a 2×2 key matrix; for three-letter blocks, use a 3×3 matrix. The plaintext vector is multiplied by the key matrix modulo the alphabet size. Encryption is $C=KP \bmod m$. Decryption is $P=K^{-1}C \bmod m$. The key must have an inverse modulo m. For the assignment's mod-36 alphabet, define 0–9 followed by A–Z. The three-character blocks can represent IDs and dosage strings after a clear rule is defined for spaces and hyphens. The determinant must be coprime with 36.

4.5 Columnar Transposition

Columnar transposition rearranges the positions of characters rather than replacing them. Write the plaintext row-wise in a grid with a number of columns equal to the keyword length. Number the columns according to the alphabetical order of the keyword letters, then read columns in that order. Decryption fills the columns in the same order and reads across the rows. A healthcare message such as PATIENTRECORDSAREPRIVATE can be placed in a grid under HOSPITAL. The final row may be incomplete, so the sender and receiver must agree on how to handle missing cells or padding.

4.6 Comparison and Selection

The methods are selected to compare substitution, polyalphabetic substitution, matrix-based block transformation and transposition. Caesar is a baseline with a very small key space. Monoalphabetic substitution demonstrates

why a large theoretical key space may still be weak. Vigenère demonstrates the effect of changing shifts. Hill demonstrates modular matrix mathematics and known-plaintext risk. Columnar transposition demonstrates diffusion of character positions without changing character counts. In the assignment, the schemes are evaluated for learning and comparison, not for real patient-data protection.

Scheme	**Key**	**Encryption rule**	**Decryption rule**
Caesar	Shift k	$C=(P+k) \bmod 26$	$P=(C-k) \bmod 26$
Monoalphabetic	Alphabet permutation	$C=\pi(P)$	$P=\pi^{-1}(C)$
Vigenère	Keyword sequence	$C_i=(P_i+K_i) \bmod 26$	$P_i=(C_i-K_i) \bmod 26$
Hill	Invertible matrix K	$C=KP \bmod m$	$P=K^{-1}C \bmod m$
Columnar	Column ordering	Read columns by key order	Rebuild grid and read rows

TASK 5 – Mathematical Analysis of the Schemes (5 Marks)

Mathematical analysis explains how many keys a cipher can use and what conditions are necessary for encryption and decryption to work. A large key space is useful because it makes exhaustive search harder, but it does not guarantee security if the cipher leaks statistical patterns or has a mathematical weakness.

5.1 Caesar Key Space

There are 26 possible shifts if the identity shift is included. Usually only 25 are meaningful because a shift of zero leaves the plaintext unchanged. An attacker can try all 25 shifts quickly. The key-space size is therefore too small to protect any sensitive message. The modular rule is $C=(P+k) \bmod 26$, with decryption $P=(C-k) \bmod 26$.

5.2 Monoalphabetic Key Space

A monoalphabetic key is a permutation of 26 letters. The first cipher letter has 26 choices, the second has 25 remaining choices, and so on. The total is $26\times25\times24\times\ldots\times1 = 26!$, approximately 4.03×10^{26}. This is much larger than Caesar's key space. However, the cipher preserves the pattern of letter frequencies. For example, the most common plaintext letter still maps to one fixed ciphertext letter, so frequency analysis can identify likely mappings. This proves that key-space size alone does not guarantee security.

5.3 Vigenère Key Space

For a key of length m, each key position can contain any of 26 letters. The number of possible keys is 26^m. For a five-letter key, the number is 26^5. The encryption equation is $C_i=(P_i+K_i) \bmod 26$. If the key is repeated, positions separated by m use the same shift. Kasiski examination searches for repeated ciphertext sequences and estimates the key length. The index of coincidence can also help identify periodic structure.

5.4 Columnar Transposition Key Space

If a transposition uses n columns, the number of possible column orders is n!. For example, a six-column arrangement has 6! possible orders. The method changes positions but preserves all letter counts exactly. A larger number of columns increases the number of possible arrangements, but the ciphertext still contains the original frequency distribution.

5.5 Hill Cipher Invertibility

For a Hill cipher, the key matrix K must have an inverse modulo m. The condition is $\gcd(\det(K),m)=1$. For modulo 26, the determinant must not be divisible by 2 or 13. For modulo 36, it must not be divisible by 2 or 3. Consider $K=[[3,3],[2,5]]$ modulo 26. Its determinant is $3\times5-3\times2=9$. Since $\gcd(9,26)=1$, an inverse exists. The adjugate is $[[5,-3],[-2,3]]$. The modular inverse of 9 modulo 26 is 3 because $9\times3=27\equiv1 \bmod 26$. Thus $K^{-1}=3\times\text{adj}(K) \bmod 26 = [[15,17],[20,9]]$. Multiplying K by this inverse gives the identity matrix modulo 26.

5.6 Mod-36 Key Conditions

For IDs and dosages, the alphabet may be defined as digits 0–9 followed by letters A–Z, giving 36 symbols. Each symbol maps to a number 0 through 35. A three-character block becomes a vector of length three, and a 3×3 matrix is used. The determinant must be coprime with 36. The sender must define padding for incomplete blocks and rules for hyphens and spaces. If symbols are silently removed, the receiver may not recover the exact patient ID or dosage.

5.7 Does a Large Key Space Guarantee Strength?

No. Key space measures the number of possible keys, not how much information the ciphertext reveals. Monoalphabetic substitution has 26! keys but preserves single-letter frequency and repeated patterns. A cryptanalyst can use language statistics to reduce the search. Similarly, a repeating Vigenère key may have 26^m

theoretical keys but repeated use exposes periodicity. Security must consider the algorithm, key length, key randomness, key reuse, known plaintext and implementation.

Scheme	**Key-space expression**	**Important weakness**
Caesar	25 non-trivial shifts	Brute force
Monoalphabetic	26!	Frequency analysis
Vigenère	26^m	Repeated-key periodicity
Columnar transposition	n!	Frequency preserved
Hill	Invertible matrices mod m	Known-plaintext linear equations

TASK 6 – Evaluate Cryptanalytic Resistance (4 Marks)

Cryptanalysis studies methods for recovering plaintext or keys without being given the secret key. This task evaluates attacks that match the structure of each selected cipher. The attacker may know the language, message format, some plaintext, or many ciphertexts. In the healthcare scenario, predictable headers and repeated messages make attacks more practical.

6.1 Brute Force Against Caesar

Caesar has only 25 non-trivial shifts. An attacker can decrypt the ciphertext using every shift and inspect which output forms readable English. The attack succeeds because the search space is extremely small. No sophisticated computer is needed. The predictable words PATIENT ID or DIAGNOSIS make it even easier to recognize the correct output.

6.2 Frequency Analysis Against Monoalphabetic Substitution

Frequency analysis counts letters in a ciphertext and compares them with expected language frequencies. In English, E, T, A, O and other letters appear more often than rare letters. A monoalphabetic cipher consistently maps one plaintext letter to one ciphertext letter, so the distribution is relabeled rather than removed. Digram and trigram analysis examines common pairs and triples such as TH, HE and ING. Repeated word patterns can reveal likely words. Long clinical notes provide enough samples for statistical analysis.

6.3 Kasiski and Index of Coincidence Against Vigenère

Kasiski examination searches for repeated sequences in ciphertext and measures the distances between them. Common factors of those distances may indicate the key length. The index of coincidence estimates the probability that two randomly selected letters are equal. When a Vigenère key repeats, letters at positions with the same key shift form groups that behave like Caesar ciphertexts. The attacker can estimate the period and then apply frequency analysis to each group. A long, non-repeating random key would change the analysis, but key distribution and secure reuse become difficult.

6.4 Known-Plaintext Attack Against Hill

Hill encryption is linear algebra over modular arithmetic. If the attacker knows plaintext blocks P and their corresponding ciphertext blocks C, the relation $C=KP$ provides equations for the unknown entries of K. With enough independent plaintext blocks, the attacker can solve for the matrix. If the plaintext block matrix is invertible modulo m, the key can be calculated as $K=CP^{-1} \bmod m$. The attack is especially relevant when messages contain predictable headers or standard templates.

6.5 Attacks Against Transposition

A transposition cipher preserves the exact count of every letter. Frequency analysis alone cannot identify the column order, but it can confirm that the ciphertext has the same letter distribution as the plaintext. An attacker can try candidate column widths, rearrange columns and search for readable language. Repeated message formats and known words can help identify the correct arrangement.

6.6 Resistance Ranking

For basic attacks, Caesar is weakest because brute force immediately tests all keys. Monoalphabetic substitution and simple transposition are also weak because they preserve strong statistical properties. Vigenère can resist simple single-letter frequency analysis, but repeated short keys are vulnerable to Kasiski and IC methods. Hill can mix letters within blocks, but known plaintext may reveal its linear key. The exact ranking depends on the attacker's information and block size; no classical scheme should be treated as modern secure encryption.

6.7 Evidence and Interpretation

A fair experiment should use the same plaintext across all ciphers, with identical preprocessing rules. Record ciphertext length, frequency counts, IC values and whether the attack recovered the message or key. A successful Caesar brute-force test should recover the plaintext with one of the shifts. A monoalphabetic frequency attack may recover common mappings but may need more text to solve every letter. Vigenère analysis should estimate a likely key period before solving each group. Hill testing should use known plaintext/ciphertext block pairs and check whether the recovered key decrypts a separate test message.

Scheme	Attack	Expected result	Reason
Caesar	Brute force	Very high success	Only 25 useful shifts.
Monoalphabetic	Frequency/digram	Often successful on long text	Stable letter mapping.
Vigenère	Kasiski/IC	Successful with repeated short key	Periodic key pattern.
Hill	Known plaintext	Can recover key with enough independent blocks	Linear equations.
Columnar	Column search/patterns	Possible with sufficient text	Position rearrangement only.

TASK 7 – Evaluate Transposition and Product Ciphers (3 Marks)

Transposition and product ciphers demonstrate how different classical operations can be combined. A transposition cipher changes the positions of letters while preserving their identities. A substitution cipher changes the letter symbols. Combining the two can hide more visible structure than either method alone, but the result is still limited by classical cryptanalysis.

7.1 Columnar Transposition Procedure

First select a keyword such as HOSPITAL. Write the plaintext in rows, using one column for each keyword letter. Determine the alphabetical order of the keyword letters and read the columns in that order. During decryption, calculate the number of rows and the length of each column, fill the columns in key order and read the grid row by row. Sender and receiver must agree on duplicate letters in the keyword, padding and treatment of spaces.

7.2 Diffusion and Frequency

The purpose of transposition in this basic setting is to spread adjacent plaintext characters across different ciphertext positions. For example, letters that originally formed a common digram may no longer be adjacent. This makes direct digram inspection harder. However, transposition does not change the total number of E, T, A or other letters. A histogram of the ciphertext has exactly the same counts as the plaintext. Therefore, transposition provides positional rearrangement but not full statistical concealment.

7.3 Substitution Followed by Transposition

A product cipher applies more than one transformation. Substitution first changes the symbols, and transposition then rearranges their positions. The resulting ciphertext does not directly preserve the plaintext's letter labels or word order. A simple frequency attack may become less informative because the symbols have been substituted and their positions rearranged. Nevertheless, the attacker may still exploit repeated patterns, known plaintext, key reuse and weaknesses in each component. Combining two weak ciphers does not automatically create a strong modern cipher.

7.4 Attack Attempt and Evidence

To evaluate the combination, encrypt the same clinical note using substitution alone, transposition alone and substitution followed by transposition. Compare frequency histograms and attempt a basic attack. Substitution alone preserves a relabeled frequency distribution. Transposition alone preserves exact letter counts. The combination changes both the labels and positions, so a simple histogram is less directly useful. However, with enough ciphertext and known message formats, an attacker can still use systematic cryptanalysis. The experiment should report which patterns remain and whether the plaintext was recovered.

7.5 Practicality in Rural Clinics

Manual encryption requires staff to remember alphabets, keywords, grid dimensions and column ordering. A single mistake may make a record unreadable. Multiple keys also increase the chance that staff write them down or share them insecurely. Basic computers can run these algorithms easily, so automated educational software is more practical than manual tables. For real patient records, the clinic should use a simple modern secure application rather than ask staff to perform classical encryption by hand.

7.6 Conclusion

A substitution-plus-transposition combination is more resistant to simple visual and frequency inspection than either component alone. It demonstrates the idea of combining transformations. However, it does not supply authenticated integrity, strong identity verification or dependable protection against modern attacks. It is appropriate for classroom comparison, not operational healthcare security.

TASK 8 – Evaluate Steganography (3 Marks)

Steganography is the practice of hiding a message inside another object so that observers may not notice that a message exists. In this assignment, a short report may be embedded in a medical scan image. The main example is Least Significant Bit (LSB) embedding. The design must consider capacity, visual quality, detectability, robustness and the special importance of medical-image accuracy.

8.1 LSB Image Embedding

In an 8-bit grayscale image, each pixel has a value from 0 to 255. The least significant bit contributes only one unit to the pixel value. To embed a message bit b, a simple method replaces the pixel's least significant bit: new_pixel=(old_pixel AND 254) OR b. Extraction reads new_pixel AND 1. For RGB images, a method may use one or more color-channel bits, but changing too many bits increases visible distortion. A header or length field is needed so the receiver knows how many bits to extract.

8.2 Capacity

If one bit is stored in each pixel of a 256×256 grayscale image, the theoretical raw capacity is 65,536 bits, or 8,192 bytes, before accounting for message length metadata and other overhead. If one bit is stored in each of three RGB channels, the theoretical capacity is larger, but the visual and statistical changes may also increase. The actual safe capacity should be conservative, especially for medical images. The report must not overwrite clinically important metadata or the original scan.

8.3 Imperceptibility and PSNR

LSB changes are usually small because a pixel changes by at most one intensity level. The mean squared error (MSE) compares original and modified pixels. PSNR is calculated as $10 \log_{10}(MAX^2/MSE)$, where MAX is 255 for an 8-bit image. A high PSNR generally indicates small numerical distortion. However, a high PSNR does not prove that an image is diagnostically safe. Medical specialists must validate any altered image, and the original diagnostic image must remain preserved.

8.4 Detectability and Chi-square Testing

Steganalysis attempts to detect hidden data. LSB replacement may disturb statistical relationships between pairs of pixel values. A chi-square test can compare observed pair frequencies with expected frequencies. A suspicious statistical pattern may indicate hidden data. The test is not perfect: it can produce false positives and false negatives, and its result depends on the image content and embedding method. Detectability should be measured across multiple images, not inferred from one sample.

8.5 Robustness and JPEG Compression

Basic LSB embedding is fragile. Resizing, filtering, color conversion and lossy JPEG compression may change pixel values and destroy hidden bits. A report embedded in a lossless image may be extracted correctly before compression but fail after JPEG conversion. The experiment should save the original image, embed the report, extract it, then create a JPEG copy and attempt extraction again. The expected result is that basic LSB data may not survive lossy compression.

8.6 Text-based Steganography

A text circular or document can hide information through whitespace, selected formatting, word choices or character patterns. For example, trailing spaces may encode binary values. Such methods have very low capacity and are easily damaged when a document is copied, reflowed or normalized. They may also be detected by examining unusual formatting. They are not appropriate for critical clinical instructions.

8.7 Encryption Compared with Steganography

Encryption makes the content unreadable without a key, while steganography attempts to hide the presence of the content. Encryption can be obvious because ciphertext looks unusual. Steganography may look like an ordinary

image but can be detected statistically. Hiding alone does not protect the report if the hidden payload is discovered. Encrypt-then-embed first encrypts the report and then hides the ciphertext. This provides an additional layer, but it does not fix LSB fragility or guarantee integrity.

8.8 Medical Safety Conclusion

A medical scan is evidence used for diagnosis. Changing pixel data may affect subtle features. The original scan must never be replaced by a stego image. Any embedded report should be stored in a separate, clearly identified copy, with metadata and checks to preserve traceability. For real systems, use a secure communication channel or approved DICOM-compatible metadata mechanisms rather than modifying diagnostic pixels without clinical validation.

Criterion	Encryption	Steganography
Primary purpose	Protect message meaning	Conceal message existence
Capacity	Depends on message and cipher format	Bounded by carrier size and embedding rate
Robustness	Ciphertext can be copied exactly	Basic LSB is fragile under image processing
Detectability	Ciphertext is visible as encrypted data	May be detected statistically
Medical risk	Does not need to alter scan pixels	Pixel modification may affect diagnosis

TASK 9 – Implement and Test (4 Marks)

This task requires implementation of the selected classical schemes and tests showing that decryption recovers the original message. A reproducible experiment must specify the programming language, input data, key values, preprocessing, padding rules and test cases. The following Python program is designed for learning and can be run with standard Python 3 without installing external libraries.

9.1 Implementation Plan

Implement each cipher as a separate function. Each encryption function accepts plaintext and a key and returns ciphertext. Each decryption function accepts ciphertext and the same key and returns recovered plaintext. The test should compare the recovered message with the original. Keep punctuation and spaces consistently, or define a normalization rule and apply it in both directions. The program should not silently discard patient-ID characters.

9.2 Python Code

The code below implements Caesar, monoalphabetic substitution, Vigenère and columnar transposition. It preserves punctuation for substitution methods. The columnar example removes spaces before encryption so that the grid example is simple; a production-quality test should preserve spaces using an agreed encoding.

9.3 Correctness Tests

For each scheme, run encrypt(message,key), then decrypt(cipher,key), and compare the recovered text with the original. Test an empty string, a single character, lowercase letters, uppercase letters, spaces, punctuation, repeated letters, long notes and text containing digits. For Hill, include blocks that exactly fill the matrix and blocks requiring padding. For mod-36, verify that every supported digit and letter maps back to the same symbol.

9.4 Reproducible Performance Test

Use identical plaintexts with 100, 1,000, 10,000 and 100,000 characters. Generate each input deterministically by repeating a fixed clinical sample. Run each algorithm several times and record the median time using time.perf_counter(). Use the same computer, Python version and process conditions. Record encryption and decryption time separately. Do not invent timings; obtain them by running the program.

9.5 Limitations

The simple demonstration code is not a secure application. It does not manage keys, authenticate users, validate prescriptions, protect data at rest or securely erase temporary values. It should never be used with actual patient records. A real system needs reviewed cryptographic libraries and modern authenticated encryption.

Code

```
import string
ALPH = string.ascii_uppercase

def caesar(text, key, decrypt=False):
    shift = (-key if decrypt else key) % 26
    out = ""
    for ch in text:
        if ch.upper() in ALPH:
            x = ALPH.index(ch.upper())
            y = (x + shift) % 26
            out += ALPH[y] if ch.isupper() else ALPH[y].lower()
        else:
            out += ch
    return out

def make_substitution(keyword):
    result = ""
    for ch in (keyword.upper() + ALPH):
        if ch in ALPH and ch not in result:
            result += ch
    return result

def mono(text, key_alphabet, decrypt=False):
    src = key_alphabet if decrypt else ALPH
    dst = ALPH if decrypt else key_alphabet
    table = str.maketrans(src + src.lower(), dst + dst.lower())
    return text.translate(table)

def vigenere(text, key, decrypt=False):
    key = ''.join(c for c in key.upper() if c in ALPH)
    if not key:
        raise ValueError("Key must contain letters")
    out, j = "", 0
    for ch in text:
        if ch.upper() in ALPH:
            a = ALPH.index(ch.upper())
            b = ALPH.index(key[j % len(key)])
            shift = -b if decrypt else b
            out += ALPH[(a + shift) % 26]
            j += 1
        else:
            out += ch
    return out

def columnar_encrypt(text, key):
    order = sorted(range(len(key)), key=lambda i: (key[i], i))
    rows = [text[i:i+len(key)] for i in range(0, len(text), len(key))]
    result = ""
```

```
    for col in order:
        for row in rows:
            if col < len(row):
                result += row[col]
    return result

def columnar_decrypt(cipher, key):
    n = len(key)
    rows = (len(cipher) + n - 1) // n
    full = len(cipher) % n
    if full == 0:
        full = n
    sizes = [rows if c < full else rows-1 for c in range(n)]
    order = sorted(range(n), key=lambda i: (key[i], i))
    cols, pos = [""] * n, 0
    for col in order:
        cols[col] = cipher[pos:pos+sizes[col]]
        pos += sizes[col]
    out = ""
    for r in range(rows):
        for c in range(n):
            if r < len(cols[c]):
                out += cols[c][r]
    return out

if __name__ == "__main__":
    msg = "PATIENT RECORDS ARE PRIVATE"
    subkey = make_substitution("CIPHER")
    cases = [
        ("Caesar", caesar(msg, 3), caesar(caesar(msg, 3), 3, True), msg),
        ("Mono", mono(msg, subkey), mono(mono(msg, subkey), subkey, True), msg),
        ("Vigenere", vigenere(msg, "CLINIC"),
         vigenere(vigenere(msg, "CLINIC"), "CLINIC", True), msg),
        ("Columnar", columnar_encrypt(msg.replace(" ", ""), "HOSPITAL"),
        columnar_decrypt(columnar_encrypt(msg.replace(" ", ""), "HOSPITAL"),
                         "HOSPITAL"), msg.replace(" ", ""))
    ]
    for name, cipher, recovered, expected in cases:
        print("\\n", name)
        print("Ciphertext:", cipher)
        print("Recovered :", recovered)
        print("Result    :", "PASS" if recovered == expected else "FAIL")
```

TASK 10 – Record and Interpret Experimental Evidence (3 Marks)

Experimental evidence is required to support the comparison between the selected ciphers. It is not enough to state that one cipher is stronger. The same input messages and testing conditions should be used so that the results can be compared fairly. This task describes the measurements, calculations, result tables and interpretation that should be included in the final report.

10.1 Letter-frequency Histograms

Count how many times each letter A–Z occurs in the plaintext and each ciphertext. Plot or tabulate the results. Caesar shifts the labels of the frequency distribution but does not remove the uneven distribution. Monoalphabetic substitution also relabels the frequencies. Columnar transposition preserves exact counts. Vigenère may make the overall distribution more uniform when the key shifts vary, although repeated key periods can still be discovered. Hill combines letters in blocks and changes simple single-letter frequency patterns.

10.2 Index of Coincidence

For a text of length N, let f_i be the count of letter i. The index of coincidence is $IC = \Sigma\, f_i(f_i-1) / [N(N-1)]$. It measures the probability that two randomly selected positions contain the same letter. Natural English text has a higher IC than uniformly random letters. A monoalphabetic substitution preserves the IC exactly because it only renames letters. Transposition also preserves it because it does not change counts. Vigenère with a repeated key may lower the overall IC, while IC calculations on groups separated by the key period may reveal language-like values.

10.3 Encryption and Decryption Time

Use a timer such as Python's time.perf_counter() immediately before and after each operation. Measure encryption and decryption separately. Repeat each measurement several times and use the median to reduce noise. Test 100, 1,000, 10,000 and 100,000 characters. Most basic substitution and transposition methods should take time approximately proportional to input length, although sorting the column order adds a small key-related cost.

10.4 Attack Success Rate

Define attack success before testing. A trial is successful if the attacker recovers the exact plaintext or key within the allowed method and time. Attack success rate is successful trials divided by total trials multiplied by 100. Use several message lengths and, if possible, several different keys. Caesar brute force should have near-certain success because all shifts can be tested. Monoalphabetic analysis may improve with longer messages. Vigenère recovery depends strongly on key length and repetition. Hill recovery depends on obtaining enough independent known-plaintext blocks.

10.5 Image Entropy, PSNR and Capacity

For image encryption experiments, calculate the histogram and Shannon entropy of the original and transformed images. Entropy is $H=-\Sigma p_i \log_2(p_i)$. A simple intensity shift modulo 256 rotates pixel values and preserves the histogram shape, so it leaks statistical structure. Pixel permutation changes pixel locations but preserves the histogram exactly; it destroys visible spatial arrangement but retains the same intensity counts. PSNR measures distortion between an original and a modified image and is useful for steganography, not as proof of cryptographic security.

10.6 Results Table and Honest Reporting

Fill in measured values only after running the tests. Record computer details, Python version, image dimensions, file format, key and number of repetitions. Do not create invented experimental values. Explain anomalies, such

as a short message producing noisy timing results or JPEG compression destroying embedded LSB bits. The interpretation should connect the measurements to the weaknesses discussed in Tasks 5 and 6.

Experiment	Input sizes / data	Record
Frequency histogram	Same plaintext for each cipher	Letter counts and visual comparison
Index of coincidence	100, 1,000, 10,000, 100,000 chars	IC per ciphertext
Timing	Four specified message lengths	Encryption and decryption seconds
Cryptanalysis	Different lengths and keys	Success/failure and time
Image test	At least 256×256 image	Histogram, entropy and recovered-image equality
Steganography	Report embedded in image	Capacity, PSNR, chi-square and JPEG extraction result

A suitable interpretation is that statistical preservation gives an attacker information even when the key space appears large. The experiment should show why Caesar, monoalphabetic substitution and transposition are weak, why repeated-key Vigenère leaks periodicity, and why Hill's linear structure is vulnerable to known plaintext.

TASK 11 – Recommend and Defend the Final Design (4 Marks)

The final design must combine cryptographic reasoning with access-control policy and practical key management. It must explain why the selected approach is better than the alternatives, identify residual risks and decide whether classical techniques can protect actual patient data. The recommendation should consider the 25 clinics and staff who may not have advanced technical training.

11.1 Classroom Design Recommendation

For the academic comparison, a layered demonstration can use Vigenère followed by columnar transposition. Vigenère illustrates changing substitutions, while transposition changes character positions. Bell-LaPadula can be used to model confidentiality decisions between staff and records. A checksum can be included to demonstrate accidental-error detection, while explaining that an unkeyed checksum is not a secure integrity mechanism. This design is useful for learning but must not be deployed for patient records.

11.2 Why Not Caesar or Monoalphabetic?

Caesar is rejected because 25 useful keys can be tested immediately. Monoalphabetic substitution has a large key space but preserves letter-frequency patterns. A long clinical note gives the attacker enough statistical information to guess common letters and repeated words. Columnar transposition alone preserves exact letter counts. These schemes are useful for explaining classical cryptography but do not provide strong confidentiality.

11.3 Vigenère and Layering

Vigenère is selected for classroom comparison because it uses a sequence of shifts rather than one fixed shift. Combining it with transposition hides some visible order and makes simple inspection harder. However, repeated use of the same keyword exposes periodicity. A layered construction does not create authentication or integrity and can still be attacked. Therefore it is not a valid replacement for modern encryption.

11.4 Access Control Design

Use the clearance hierarchy from the scenario as a starting point. Add role-based permissions and patient assignment checks. A nurse should access only patients under their care, a specialist should access relevant consultation records, and billing staff should see only billing fields. Break-glass access should be time-limited, justified, logged and reviewed. High-level information should not be copied into lower-level billing records without a trusted declassification step.

11.5 Key Distribution Across 25 Clinics

A single key shared by all clinics creates a large compromise. If one clinic loses the key, the confidentiality of messages from every clinic using it may be affected. A classroom improvement is to assign a different key to each clinic and rotate keys periodically. A fresh session key for each exchange reduces the number of messages protected by one key. Key rotation should occur after staff departure, suspected compromise or a defined schedule. Keys must not be written in open notebooks or shared through ordinary email.

11.6 Usability for Rural Clinics

The system should hide cryptographic complexity from end users. Staff should sign in using a simple, secure workflow and select a patient and task. Encryption and decryption should happen automatically in the application. Clear status messages should show whether a prescription was sent, received and acknowledged. Offline queues and safe synchronization can support limited connectivity. Training should focus on recognizing suspicious requests, protecting login credentials and reporting lost devices.

11.7 Residual Risks and Real Deployment

Classical ciphers cannot reliably provide modern confidentiality, integrity, authentication or non-repudiation. A real system needs authenticated encryption, modern key exchange and key management, strong user authentication, role-based access, digital signatures where appropriate, audit logging, backups, endpoint protection and incident response. It must also comply with applicable privacy, medical-record and data-protection requirements. The final verdict is that classical ciphers are not acceptable as the primary protection for patient data.

Design element	Recommendation	Purpose
Encryption	Modern authenticated encryption in real deployment	Confidentiality and tamper detection
Identity	Unique staff accounts and strong authentication	Identify users
Authorization	BLP-inspired labels plus role and patient checks	Limit access
Keys	Per-clinic and managed session keys	Limit compromise scope
Audit	Tamper-evident access and prescription logs	Accountability
Availability	Backups and downtime workflow	Continuity of care

TASK 12 – Day-4 Design Challenge: Re-evaluate and Adapt (8 Marks)

The changed scenario states that an insider at a satellite clinic has copied ciphertexts for months. Hundreds of messages use the same key, and many begin with predictable headers such as PATIENT ID, DIAGNOSIS and PRESCRIPTION. The network also wants to hide a short report inside medical scan images. This change requires a fresh threat assessment because the attacker has repeated ciphertexts and may know part of the plaintext.

12A. Impact Analysis

The threat has changed from a general external attacker to an insider who may already have legitimate access to a clinic system. The insider may know message formats, patient-record templates, staff routines and key locations. The earlier assumption that the key remains secret at all 25 clinics is no longer reliable. Reuse of one key creates a large collection of related ciphertexts. Predictable headers provide known-plaintext information. Repeated messages can help an attacker identify patterns and estimate key properties. The risk ranking must therefore give greater weight to insider collection, key compromise and offline cryptanalysis.

12B. Test the Original Design

If the original design uses Caesar, an attacker can try every shift. If it uses monoalphabetic substitution, hundreds of messages provide strong letter-frequency evidence. If it uses repeating-key Vigenère, known headers help calculate key letters at corresponding positions using $K_i=(C_i-P_i) \bmod 26$. Repeated headers may reveal the same key positions across multiple messages. If Hill is used, known plaintext blocks and their ciphertext counterparts may provide enough equations to recover the matrix, provided the relevant matrices are invertible. Columnar transposition preserves letter counts and repeated message templates can help reconstruct the column order.

12C. Role of Bell-LaPadula Under Insider Threat

BLP continues to enforce read and write restrictions inside the network. It may prevent a Confidential nurse from reading a Secret specialist file. However, if an insider is authorized to read a record or copy ciphertexts, BLP alone does not prevent offline analysis. If the insider has access to the shared key, the confidentiality model cannot restore secrecy. BLP is an authorization model, not a substitute for cryptographic key protection, monitoring or insider-risk controls.

12D. Adaptation – Per-Clinic Keys

Replace the one shared clinic key with a unique key for each satellite clinic. A compromise at one clinic should not automatically expose every other clinic's communications. The central hospital must maintain a secure mapping between clinic identity and its key. When a clinic is compromised, revoke and replace only its key, while investigating records protected by the old key. This approach reduces the scope of a compromise but does not prevent the compromised clinic from exposing its own records.

12E. Adaptation – Per-Session Keys and Rotation

Use a fresh session key for each exchange or short communication period in the educational redesign. This reduces the number of ciphertexts available under one key. Rotate keys after suspected compromise and at defined intervals. In real deployments, session-key establishment and rotation must be automated and protected by modern cryptographic protocols. A handwritten classical key exchange would create additional risks and staff burden.

12F. Adaptation – Reduce Predictable Structure

Avoid placing fixed headers in plaintext. Include required metadata inside the protected message, or use standardized protected framing. Randomized padding can make messages of similar content less distinguishable by length, although padding must be implemented correctly. Removing predictable text does not eliminate

known-plaintext attacks if the attacker knows the message format from other sources. It is only a risk-reduction measure.

12G. Adaptation – Encrypt Then Embed

If a short report must be hidden in a scan image for an approved demonstration, encrypt the report first and then embed the ciphertext in a separate copy of the image. The recipient extracts the payload and decrypts it. This means that discovery of the hidden data does not immediately reveal the report. However, LSB embedding may be detected and may fail after JPEG compression or image processing. The original medical image must remain unchanged and available for diagnosis. A hidden report must never alter or replace the authoritative clinical scan.

12H. Key Space and Attack Effort

A larger key space may increase brute-force effort, but it does not remove structural weaknesses. Per-clinic keys reduce the number of messages exposed by one compromised key. Per-session keys reduce ciphertext volume per key. Randomized padding reduces predictable message structure. Yet a repeated-key Vigenère cipher can still be attacked if enough data under a session key is collected, and a known-plaintext Hill attack may still recover a key. The improvement is mainly containment and reduced data exposure, not modern cryptographic strength.

12I. Usability and Cost

Twenty-five clinic keys require secure creation, distribution, backup, rotation and revocation. Per-session keys add further operational complexity. A central automated key-management service can reduce manual work, but it must be reliable and protected. Clinic staff should not need to memorize cipher alphabets or manually calculate matrices. The application should perform all encryption and key handling automatically. A lost device or suspected insider incident should trigger a simple reporting and revocation process.

12J. Final Evidence-Based Decision

The final classroom decision is to modify the design: use unique clinic keys, short-lived session keys, rotation, reduced predictable structure, strict access logging and encrypt-then-embed only for a demonstration copy. The mathematical analysis shows that key-space size is not enough; frequency leakage, periodicity and linearity remain exploitable. Experimental evidence should compare the original repeated-key design with the modified key separation and report attack success, not claim perfect security. For real patient data, replace all classical ciphers with modern authenticated encryption and professionally managed identity and keys. Classical techniques cannot guarantee secure authentication, tamper detection, non-repudiation or resistance to modern cryptanalysis.

Changed risk	Design response	Remaining limitation
Insider copies ciphertext	Audit, investigate, revoke access and keys	Authorized users may still misuse access.
Same key reused	Per-clinic and per-session keys	Key management becomes more complex.
Predictable headers	Protect metadata and use suitable padding	Known plaintext may still be available.
Hidden image report	Encrypt then embed in a separate copy	LSB is fragile and detectable.
Emergency access	Break-glass with logging and review	Requires governance and monitoring.